

Cyber Tabletop Exercise

Cloud Misconfiguration Exposing KYC and Mortgage Documents

Revised facilitation-ready exercise package

Item	Description
Exercise type	Facilitated tabletop exercise
Scenario source	Structured STIX-like scenario transformed into a professional TTX and revised using evaluation feedback
Sector	Financial services / banking
Primary business area	Digital onboarding, KYC, and mortgage workflows
Cloud platform selected	Microsoft Azure – Azure Blob Storage
Duration	90 minutes baseline; 120 minutes extended with branching injects
Audience	Executive, crisis management, SOC, cloud operations, legal/privacy, compliance, fraud, communications, business operations
Baseline adversary position	No confirmed malicious adversary activity. The baseline event is a misconfiguration-driven public data exposure reported by an external researcher. Optional branches can introduce evidenced malicious bulk access.

Facilitator orientation

This package is designed for live facilitation. It includes timed injects, expected actions, escalation triggers, technical evidence, branching variations, evaluation criteria, and an evidence-aware MITRE ATT&CK mapping. The exercise should be run as a no-fault discussion focused on decision quality, coordination, and control improvement.

1. Executive Summary

This tabletop exercise simulates a public exposure of sensitive customer onboarding and mortgage documentation caused by a cloud storage permissions misconfiguration. The exercise tests the organization's ability to validate a suspected public data exposure, contain cloud access without destroying evidence, scope customer and regulatory impact under logging uncertainty, coordinate executive decisions, and define durable cloud governance improvements.

The revised version strengthens realism by selecting a specific cloud platform, identifying concrete logging sources, clarifying the control state at the start of the exercise, and explicitly linking configuration changes to visibility gaps and decision thresholds. It also separates confirmed evidence from hypothetical adversary behaviors in the MITRE ATT&CK mapping.

Baseline scenario position

The baseline scenario is a confidentiality and cloud governance incident. It does not assume ransomware, malware, credential theft, or destructive activity. External access is confirmed only to the extent that a researcher was able to retrieve redacted examples from public URLs. Any malicious bulk access is introduced only through optional branching injects.

2. Contents

- 1. Executive Summary
- 2. Contents
- 3. Feedback Integration Summary
- 4. Exercise Objectives
- 5. Scope, Assumptions, and Exercise Constraints
- 6. Banking Environment and Cloud Architecture
- 7. Control State at Exercise Start
- 8. Participant Roles and Escalation Model
- 9. Rules of Engagement
- 10. Facilitation Plan and Timing
- 11. Scenario Narrative and Causal Chain
- 12. Exercise Narrative and Injects
- 13. Optional Branching Injects and Technical Variations
- 14. Key Decision Points
- 15. Technical and Business Impacts
- 16. Evaluation Criteria and Success Metrics
- 17. Debrief and After-Action Review
- 18. Improvement Planning Template
- 19. Optional Exercise Artifacts
- 20. MITRE ATT&CK Mapping
- 21. Glossary
- 22. Source-to-Scenario Traceability

3. Feedback Integration Summary

The following table documents how the evaluation feedback was integrated into this revised TTX design.

Evaluation area	Feedback	Integration in revised exercise
Realism	Add specific cloud platform, logging sources, and control-state details.	Selected Microsoft Azure Blob Storage; added Azure Activity Logs, Entra ID audit/sign-in logs, Azure Storage resource logs, Log Analytics/Sentinel, Defender for Cloud, IaC pipeline evidence, CDN/WAF logs, and a control-state table.
Coherence and consistency	Clarify causal links between configuration changes, logging gaps, decision thresholds, and timeline transitions.	Added a causal chain from change request to public access, policy audit-only state, missing data-plane logs, scoping uncertainty, and escalation thresholds.
Relevance	Tailor regulatory and organizational context to banking.	Focused on KYC onboarding, mortgage records, customer identity documents, fraud monitoring, banking supervisors, privacy authorities, consumer protection, and board/executive decisioning.

Evaluation area	Feedback	Integration in revised exercise
Cyber accuracy	Define adversary activity and map only evidenced ATT&CK techniques.	Baseline explicitly contains no confirmed malicious adversary. ATT&CK mapping separates confirmed, inferred, branch-dependent, and not-evidenced techniques.
Training value	Introduce branching injects or technical variations.	Added optional branches for delayed containment, evidence loss, clean containment, bulk external access, and business continuity decisions.
Structural completeness	Add formal evaluation criteria, success metrics, inject delivery guidance, and escalation mechanics.	Added RACI-style roles, escalation triggers, inject delivery methods, success metrics by time horizon, scoring rubric, and observer note templates.

4. Exercise Objectives

By the end of the exercise, participants should be able to:

1. Validate and classify a suspected public cloud data exposure affecting sensitive banking, KYC, and mortgage records.
2. Execute urgent cloud containment actions while preserving evidence, documenting decisions, and maintaining chain of custody.
3. Use Azure control-plane logs, cloud configuration evidence, change records, and partial data-plane visibility to estimate exposure scope.
4. Distinguish confirmed facts, bounded assumptions, and unresolved uncertainty when making regulatory, customer, and business decisions.
5. Escalate effectively across SOC, cloud operations, business owners, legal, privacy, compliance, communications, fraud, executive leadership, and board-level stakeholders.
6. Determine notification thresholds and timing for regulators, affected customers, internal stakeholders, partners, and customer-facing teams.
7. Evaluate whether digital onboarding and mortgage workflows can continue safely under compensating controls.
8. Define a concrete 0–7 day, 30 day, and 60–90 day control uplift plan for cloud storage governance and sensitive document protection.

5. Scope, Assumptions, and Exercise Constraints

5.1 In scope

- Azure Blob Storage used by digital onboarding, KYC review, and mortgage workflows.
- Customer identity documents, proof-of-address files, income evidence, tax forms, credit reports, and mortgage application artifacts.
- Cyber incident response, cloud containment, evidence preservation, and exposure scoping.
- Privacy, legal, regulatory, fraud, customer protection, business continuity, and communications decision-making.
- Crisis escalation from operational incident response to executive and board-level awareness.
- Enterprise review of similar cloud repositories and control uplift planning.

5.2 Out of scope

- Detailed legal advice for a specific jurisdiction.
- Live technical testing against production systems.
- Full forensic reconstruction of every access event where logging was not configured.
- Attribution of malicious actors unless the facilitator activates an optional branch with additional evidence.
- Detailed vendor contract review, unless participants identify it as an improvement action.

5.3 Key assumptions

Assumption	Details
Production data	The exposed storage account contains production customer files, not synthetic or test data.
Data sensitivity	Documents include personally identifiable information, government ID images, financial records, and mortgage application materials.
No baseline malware	No ransomware, destructive activity, privilege escalation, or credential theft is observed in the baseline scenario.

Assumption	Details
Logging uncertainty	Azure Activity Logs and change pipeline evidence exist, but pre-discovery object-level read logs are incomplete.
Process maturity	The organization has incident response, privacy, crisis escalation, and communications processes, but cloud-specific playbooks and decision thresholds are uneven.
Jurisdiction	The facilitator should localize regulatory names and statutory timing. The exercise uses banking-specific governance without giving legal advice.

6. Banking Environment and Cloud Architecture

The organization is a banking institution operating digital onboarding and mortgage workflows. Customers upload identity documents and mortgage evidence through a secure web portal. Documents are stored in Azure Blob Storage and retrieved by internal KYC, fraud, lending, and servicing teams through authenticated applications.

Component	Exercise detail
Customer-facing portal	Digital Onboarding Portal hosted in Azure App Service behind Application Gateway and WAF.
Document API	Document Upload API uses a managed identity to write customer files to Azure Blob Storage.
Storage account	Storage account: prod-doc-onboarding-eus2. Primary container: customer-documents. Expected access level: Private.
Document path model	/prod/onboarding/{year}/{customer-id}/{document-type}/{file-id}.pdf. Object keys are not intended to be public but may be inferable from portal error messages and support logs.
Identity	Application access uses managed identities. CI/CD uses service principal spn-docops-prod with rights to deploy storage account and container settings.
Security tooling	Microsoft Defender for Cloud, Microsoft Sentinel, Entra ID audit/sign-in logs, Azure Policy, Azure Monitor, Log Analytics, CSPM posture management, and DLP/classification tooling.
Business dependencies	Digital onboarding, KYC review, mortgage intake, fraud monitoring, customer contact center, and document retention workflows.

6.1 Banking data categories in scope

Data category	Examples	Risk considerations
Identity and KYC	Passport, driver's licence, national ID, proof of address, customer profile forms.	High risk of identity theft, account takeover, social engineering, and regulatory scrutiny.
Mortgage application	Income statements, employment letters, bank statements, tax forms, property documents.	Financial sensitivity, consumer harm, reputational impact, and possible notification obligations.
Credit/fraud data	Credit bureau response artifacts, fraud flags, internal notes where present.	Sensitive customer profiling and potential unfair-impact concerns if exposed.
Operational metadata	Customer IDs, document types, upload timestamps, reviewer comments.	Can assist targeted phishing or social engineering even when document contents are not accessed.

7. Control State at Exercise Start

The following control-state snapshot is provided to facilitators. It can be disclosed gradually as participants ask questions or as injects progress.

Control	Expected state	Actual state at start	Consequence
Azure Storage public access	allowBlobPublicAccess = false at the	Storage account allows blob public	Anyone with a valid object URL can

Control	Expected state	Actual state at start	Consequence
	storage account; container access level = Private.	access; customer-documents container has publicAccess = Blob.	retrieve the blob without authentication.
Network access	Public network access disabled; Private Endpoint required from bank-managed networks.	Public network access enabled from all networks due to legacy vendor test exception.	The storage endpoint is reachable from the internet.
Azure Policy	Policy denies public blob access and public network exposure for sensitive repositories.	Policy assignment set to AuditIfNotExists during migration; no blocking guardrail.	Misconfiguration is detected as noncompliant but not prevented.
CSPM monitoring	Critical alert routed to Sentinel when sensitive storage becomes public.	Connector exists, but this storage account lacks a sensitive-data tag and alert routing is informational.	SOC does not receive a high-confidence alert before researcher disclosure.
Storage data-plane logs	StorageRead and StorageWrite logs sent to Log Analytics with 180-day retention.	StorageWrite logs exist; StorageRead logs were not enabled until after triage.	Pre-triage GetBlob access cannot be fully reconstructed.
Azure Activity Logs	Control-plane changes retained for 90 days.	Available. Shows CI/CD service principal changed container ACL and network settings.	Supports root-cause timeline but not object-level customer impact.
Application/WAF/CDN logs	Customer portal access logs retained for 90 days and correlated to object access.	Application Gateway and WAF logs retained 30 days; do not cover direct blob endpoint access.	Useful only for portal-mediated access, not anonymous direct access.
Change management	Security and data owner approval required for production storage permission changes.	Emergency hotfix merged with platform approval but no data owner sign-off.	Business risk owner was not aware of public-access risk.
Data classification	All customer documents tagged Confidential – Customer Restricted.	Classification covers approximately 60% of documents; legacy mortgage scans lack metadata.	Scoping requires object inventory and content sampling.
DLP/fraud controls	DLP detects suspicious outbound movement; fraud monitoring is triggered for exposed high-risk data.	DLP does not inspect anonymous cloud reads; fraud monitoring requires customer list from scoping.	Customer protection response depends on rapid impact estimation.

8. Participant Roles and Escalation Model

8.1 Core roles

Role	Primary responsibilities during exercise
Incident Commander / Cyber IR Lead	Owns incident cadence, decision log, evidence preservation plan, severity recommendation, and cross-functional coordination.
SOC	Validates report, queries SIEM/Sentinel, preserves indicators, monitors for exploitation, and provides technical updates.
Cloud Platform / Cloud Security	Confirms Azure configuration, executes emergency containment, exports control-plane and data-plane evidence, and validates no similar public exposure exists.
Application Owner	Assesses digital onboarding and mortgage workflow dependencies, validates whether new documents continue writing to the affected container, and proposes compensating controls.
Business Owner – Digital Banking / Lending	Owns operational risk decisions such as pause, continue, reroute, or backlog affected workflows.
Privacy / Data Protection	Assesses data classes, customer harm, breach/reportability thresholds, and notification obligations.
Legal Counsel	Advises on privilege, regulator/customer notification, researcher communications, contractual exposure, and litigation preservation.
Compliance / Regulatory Affairs	Coordinates banking supervisor engagement, regulatory timeline, incident reporting format, and post-mortem expectations.
Fraud / Customer Risk	Assesses identity theft and account takeover risk; designs enhanced monitoring and customer-protection measures.
Corporate Communications	Prepares holding statements, employee talking points, contact-center

Role	Primary responsibilities during exercise
	scripts, media response, and executive messaging.
Executive / Crisis Lead	Chairs crisis cell when thresholds are met, approves major business and communications decisions, and briefs board or board committee.
Records / Data Governance	Supports object inventory, retention requirements, records hold, and classification gap analysis.

8.2 Escalation mechanics

Trigger	Escalation action
Credible report of public access to customer documents	SOC opens high-priority incident, names Incident Commander, starts decision log, notifies cloud platform, application owner, privacy, legal, and compliance.
Public access confirmed for high-risk customer information	Activate cyber crisis bridge and notify executive crisis lead; assess whether privacy incident and security incident classifications apply.
Potentially affected customers exceed initial materiality band or include government ID/income documents	Prepare executive situation report; engage fraud/customer risk; prepare regulator and customer notification decision memo.
Media inquiry, public speculation, or customer complaint	Activate communications lead and contact center leadership; approve holding statement and internal talking points.
Evidence of bulk download, object listing, or malicious automation	Escalate to confirmed malicious access branch; consider law enforcement, threat intelligence, enhanced monitoring, and updated ATT&CK mapping.
Business workflow interruption or risk of newly uploaded documents entering exposed storage	Crisis lead and business owner decide whether to pause, reroute, or continue with compensating controls.
Regulatory notification likely or board visibility required	Executive sponsor briefs board/committee and authorizes external engagement path with legal/privacy/compliance.
Governance correction embedded in this version The SOC and Incident Commander may initiate emergency containment and recommend severity. The crisis cell does not direct low-level technical actions; it owns cross-functional decisions, executive visibility, business risk acceptance, regulatory posture, and communications approval.	

9. Rules of Engagement

- This is a no-fault learning exercise intended to improve readiness.
- Real-world incidents take priority.
- Participants should respond according to current roles, responsibilities, tools, and processes.
- Participants may make reasonable assumptions, but the facilitator should record assumptions separately from confirmed facts.
- The scenario is fictionalized but should be treated as realistic.
- The impacted cloud service is selected to initiate discussion, not because of a known concern with a specific system or vendor.
- Do not fight the scenario. Focus on decision quality, escalation, accountability, evidence, communications, and control improvement.
- The facilitator should not disclose all technical facts upfront. Provide evidence as participants ask credible questions or as injects mature.

10. Facilitation Plan and Timing

Segment	Baseline 90-minute run	Extended 120-minute run
Introduction, objectives, roles, rules	10 minutes	15 minutes
Inject 1 – Researcher disclosure	15 minutes	15 minutes
Inject 2 – Containment and control-state evidence	15 minutes	20 minutes
Inject 3 – Scoping and notification dilemma	20 minutes	25 minutes

Segment	Baseline 90-minute run	Extended 120-minute run
Inject 4 – External pressure and operational decision	15 minutes	20 minutes
Inject 5 – Governance, reporting, and control uplift	10 minutes	15 minutes
Final debrief and scoring	5 minutes	10 minutes

10.1 Inject delivery guidance

- Deliver each inject verbally and, where useful, as a printed or projected artifact.
- Maintain a visible decision log with time, owner, decision, rationale, and open questions.
- Use the optional branches only when they reinforce the learning objective or when participant decisions create a realistic consequence.
- Separate technical evidence from interpretation. For example, “StorageRead logs are missing before 09:55” is a fact; “there was no access before 09:55” is not supported.
- Pause after each inject to ask participants what they know, what they assume, what decisions are needed now, and what evidence they need next.
- Observers should score performance against the evaluation rubric in Section 16.

11. Scenario Narrative and Causal Chain

The organization operates cloud-hosted digital onboarding and mortgage workflows. Customer documents are stored in Azure Blob Storage. A production hotfix unintentionally changes storage container permissions and leaves sensitive customer documents reachable from the public internet if the object URL is known.

Relative time	Event	Causal link / evidence
T–10 days	A vendor testing exception is requested to support a document scanning integration.	Public network access is temporarily allowed for the storage account. Exception is not bounded tightly enough.
T–5 days	IaC module parameter defaults are changed during an urgent deployment fix.	The default publicAccess value for the customer-documents container changes from None to Blob.
T–4 days	Azure Policy assignment remains AuditIfNotExists rather than Deny for the onboarding resource group.	The misconfiguration is recorded as noncompliant but not prevented.
T–3 days, 18:47	CI/CD service principal spn-docops-prod deploys updated storage settings.	Azure Activity Logs show container write operation and network rule update.
T–2 days	Object URLs appear in a support log excerpt attached to a troubleshooting ticket.	A valid object URL can now be used without authentication because anonymous blob read is enabled.
Day 0, 09:00	External researcher reports public access to customer mortgage and onboarding documents.	Initial detection comes externally because data-plane read logging and CSPM routing were insufficient.
Day 0, 09:25–10:00	Cloud team contains public access and starts evidence preservation.	Immediate containment reduces exposure but missing pre-triage StorageRead logs limit proof of who accessed files.
Day 0, 11:00	Scoping begins with object inventory, data classification, Activity Logs, IaC history, support tickets, and partial read logs.	Legal/privacy must decide whether incomplete logs create a reportability threshold despite no confirmed malicious bulk download.
Day 0, 15:00	A journalist contacts communications and business leaders ask whether onboarding can continue.	The incident becomes both a technical containment issue and an executive crisis coordination issue.
Day 1, 10:00	Root cause, residual uncertainty, notification recommendation, and control uplift plan are requested.	Leadership must decide how to communicate uncertainty and fund durable controls.

12. Exercise Narrative and Injects

Inject 1 — External Researcher Disclosure

Field	Details
Exercise time	Day 0, 09:00
Recommended delivery	Email artifact from security mailbox plus redacted document screenshots. Do not provide cloud configuration details unless participants ask for validation evidence.
Scenario text	A security researcher contacts the bank's security mailbox and states that several customer mortgage and onboarding documents are publicly accessible from Azure Blob Storage without authentication. The researcher provides redacted screenshots and three example object URLs and requests acknowledgement within 24 hours.

What participants know

- The report appears credible and includes redacted examples of real customer documents.
- The URLs point to the bank's Azure Blob Storage account used by digital onboarding.
- There is no confirmed malicious exploitation, ransomware, or destructive activity.
- The researcher says they accessed only enough files to validate the issue.
- The security mailbox receives the message before the SOC receives any automated alert.

Key discussion prompts

- How is the report validated and triaged without increasing exposure?
- Who owns incident command, evidence preservation, and emergency containment authority?
- What evidence is captured before permissions are changed?
- Which stakeholders must be engaged in the first hour?
- Who approves communication back to the researcher, and what is said?
- What severity and incident classifications are appropriate based on current facts?

Expected actions

- Open a high-priority incident and assign an Incident Commander.
- Validate the URLs from a controlled environment and capture timestamps, headers, screenshots, and object metadata.
- Notify cloud platform, cloud security, application owner, privacy, legal, compliance, and business owner.
- Start a decision log and evidence log.
- Prepare an emergency containment plan that preserves pre-change configuration state.
- Acknowledge the researcher through approved legal/security communications channels.

Observable success indicators

- Incident Commander named within 10 minutes of discussion.
- Evidence owner and containment owner are distinct and clearly assigned.
- Participants distinguish confirmed public access from unconfirmed malicious access.
- Legal/privacy are engaged before external acknowledgement is sent.

Facilitator notes

Push the team to balance urgency and evidence. Strong teams do not wait for perfect scoping before containment, but they capture enough pre-change state to explain what changed, who changed it, and what remains unknown.

Inject 2 — Containment and Control-State Evidence

Field	Details
Exercise time	Day 0, 10:15
Recommended delivery	Cloud engineering update with Azure configuration excerpt and partial log inventory.
Scenario text	Cloud engineering confirms that the storage account prod-doc-onboarding-eus2 allowed public blob access and that the customer-documents container was set to publicAccess = Blob. The account also allowed public network access from all networks. Azure Activity Logs show the setting was changed by the CI/CD service principal spn-

Field	Details
	docops-prod three days earlier. StorageRead logs were not being sent to Log Analytics before 09:55 today.

What participants know

- Public access is technically confirmed.
- The container permits anonymous read of known blob URLs, but container listing is not confirmed in the baseline.
- Azure Activity Logs identify the control-plane change, but pre-09:55 object read logs are incomplete.
- The change appears related to a production hotfix and a legacy vendor testing exception.
- Cloud posture monitoring flagged noncompliance as audit-only, not as a blocking or high-severity alert.

Key discussion prompts

- What containment action is fastest and least destructive: change container ACL, disable account-level public access, restrict network access, rotate SAS policies, or a combination?
- How do you preserve evidence before and after containment?
- What compensating controls are needed while scoping continues?
- How do you prevent new documents from entering the affected exposure path?
- What facts are now strong enough to escalate to crisis leadership?
- How do the missing StorageRead logs affect exposure estimation?

Expected actions

- Disable anonymous public access at the storage-account and container level.
- Restrict public network access and confirm private endpoint/application access still functions where needed.
- Export Activity Logs, ARM/IaC state, policy compliance history, diagnostic settings, container properties, sample object metadata, and change records.
- Enable StorageRead logs immediately and preserve Log Analytics retention.
- Suspend or reroute new uploads if the write path remains tied to the affected container.
- Create a fact/assumption/unknown matrix for privacy and executive decision-making.

Observable success indicators

- Public access removed or compensating controls decided within the discussion window.
- Evidence checklist includes control-plane and data-plane sources.
- Participants do not claim “no access” merely because logs are missing.
- Business owner is engaged on whether new uploads continue.

Facilitator notes

Probe whether participants know exactly who can change Azure storage settings under emergency conditions. Ask whether containment is documented as an emergency change and whether participants can validate that public access was removed from the internet.

Inject 3 — Scoping and Notification Dilemma

Field	Details
Exercise time	Day 0, 12:30
Recommended delivery	Incident bridge update with object inventory and data classification estimate.
Scenario text	Initial inventory identifies approximately 18,420 objects in the exposed container, associated with 8,700 possible customers. About 2,350 objects contain government identity documents, 1,100 contain mortgage income evidence, 650 contain tax-related documents, and a subset includes credit bureau artifacts. Classification metadata is incomplete for legacy scans. There is no conclusive evidence of mass download, but pre-triage object-read logs are incomplete.

What participants know

- The exposed data includes high-risk identity and financial information.
- The exact exposure window is bounded by the CI/CD change but object-level access evidence is incomplete.
- Customer impact can be grouped into confirmed, probable, and possible bands.
- The organization cannot rule out third-party access during the exposure period.
- Fraud monitoring requires a preliminary customer list but customer lists may evolve.

Key discussion prompts

- What is the minimum evidentiary standard for treating this as a reportable breach or privacy incident?
- How do you estimate the exposure window and affected population with incomplete logs?
- Which data categories change notification urgency?
- What should be communicated to executives while facts are incomplete?
- Do you notify regulators before customer count is final?
- What fraud and identity-protection measures should start now?

Expected actions

- Build a customer impact matrix: confirmed, probable, possible, excluded.
- Correlate object inventory with customer master records, upload timestamps, application status, and data classification.
- Use Activity Logs, IaC commits, support tickets, WAF/CDN logs, and researcher artifacts to bound exposure.
- Engage legal/privacy/compliance to decide notification path and timing.
- Prepare draft regulator briefing, internal leadership update, customer Q&A, and contact-center script.
- Begin fraud monitoring and identity-protection planning for high-risk customer bands.

Observable success indicators

- Customer impact bands are defined with clear evidence criteria.
- Legal/privacy decision path is documented with assumptions.
- Executive update separates confirmed facts, likely impacts, and unknowns.
- Fraud/customer-protection planning begins before final customer count.

Facilitator notes

Good participants will be uncomfortable with uncertainty but still make decisions. Challenge overconfident statements. Ask whether “absence of evidence” is being confused with “evidence of absence.”

Inject 4 — External Interest and Operational Pressure

Field	Details
Exercise time	Day 0, 15:00
Recommended delivery	Communications update plus business operations request.
Scenario text	A journalist contacts corporate communications stating they received a tip that a bank cloud repository exposed customer mortgage records. Social media monitoring shows early speculation, but no leaked files are visible publicly. Business leadership asks whether digital onboarding and mortgage intake can continue safely. The contact center asks for guidance in case customers call.

What participants know

- Media awareness may be emerging.
- Customer harm is not confirmed, but the risk is credible.
- The affected workflow is business-critical for onboarding and mortgage processing.
- New customer documents must not enter an exposed or inadequately logged storage path.
- Communications, legal, privacy, and business leadership now require aligned messaging.

Key discussion prompts

- What is the communications posture before public confirmation?
- What message goes to employees, executives, customer-facing teams, and relationship managers?
- Do you continue, restrict, pause, or reroute onboarding and mortgage workflows?
- Who approves customer-facing and media statements?
- What evidence threshold triggers proactive customer notification?
- How do you avoid inconsistent messaging between legal caution and customer transparency?

Expected actions

- Approve a holding statement and internal talking points.
- Establish contact-center scripts and escalation paths.
- Decide whether operations continue with compensating controls, pause, or reroute to a clean repository.
- Document business risk acceptance if workflows continue.
- Prepare board/executive briefing if media exposure or notification is likely.
- Coordinate fraud, privacy, legal, and communications actions.

Observable success indicators

- Clear owner for external statements and customer support scripts.
- Business continuity decision includes technical preconditions.
- Participants consider customer trust and fraud risk, not only legal minimums.
- Executive/board escalation threshold is explicit.

Facilitator notes

Look for coordination breakdowns. A mature response aligns legal, communications, business continuity, and customer protection without waiting for perfect technical certainty.

Inject 5 — Containment Complete, Governance Questions Remain

Field	Details
Exercise time	Day 1, 10:00
Recommended delivery	Executive request for incident summary and control uplift plan.
Scenario text	Cloud security confirms public access has been removed and verified from an external test environment. Preliminary root cause points to an IaC default value, a legacy network exception, audit-only Azure Policy, and incomplete StorageRead logging. There is still no conclusive evidence of mass download in the baseline scenario, but the organization cannot prove that no external party accessed documents during the exposure window. Leadership requests a formal incident summary, notification recommendation, and 30/60/90-day control-improvement plan.

What participants know

- Active exposure is contained.
- Root cause is a cloud configuration and governance failure, not malware.
- Residual uncertainty remains due to missing pre-triage StorageRead logs.
- Control failures include change management, preventive guardrails, logging, data classification, and monitoring.
- Regulatory, customer, and board decisions must be made with imperfect evidence.

Key discussion prompts

- What should the executive recommendation include?
- How do you document residual uncertainty for regulators and customers?
- What corrective actions are mandatory in the next 7, 30, 60, and 90 days?
- How will the organization validate that similar exposures do not exist elsewhere?
- Who owns closure of each improvement action?
- What evidence package is retained for post-mortem, regulator review, or litigation hold?

Expected actions

- Produce a concise incident summary with facts, assumptions, timeline, impact, decisions, and open items.
- Decide regulator/customer notification path and timing.
- Launch enterprise cloud exposure review across sensitive repositories.
- Set Azure Policy to deny public access for sensitive storage and remove legacy public network exceptions.
- Mandate StorageRead logging and retention for sensitive repositories.
- Create owner-assigned 0–7 day, 30 day, and 60–90 day control uplift actions.
- Schedule after-action review and track actions to closure.

Observable success indicators

- Executive summary contains decision-ready recommendation.
- Control plan is owner-assigned and measurable.
- Regulatory/customer notification rationale is documented.
- Enterprise-wide cloud posture review is initiated.

Facilitator notes

Encourage specificity. Strong teams define owners, dates, measurable control outcomes, and validation evidence. Weak answers remain generic, such as “improve monitoring.”

13. Optional Branching Injects and Technical Variations

Use branching injects selectively. They are designed to increase training depth and to test the consequences of participant decisions without making the baseline scenario contradictory.

Branch	Trigger	Inject text	Learning objective	ATT&CK impact
A – Delayed containment	Participants wait for full scoping before containment.	At 10:45, the researcher replies that the example URLs are still public and asks whether they should begin coordinated disclosure through a vulnerability platform.	Tests urgency, containment authority, and researcher communication.	No new adversary technique; exposure remains misconfiguration-driven.
B – Evidence loss	Participants order immediate deletion or broad changes without evidence capture.	Cloud team reports that pre-containment container settings and object metadata were not fully exported, complicating root-cause and exposure scoping.	Tests evidence preservation and chain of custody.	No new adversary technique; evidentiary confidence decreases.
C – Clean containment	Participants contain quickly and preserve evidence.	External validation confirms the URLs now return access denied. Post-09:55 StorageRead logs show only controlled validation and researcher IP access.	Reinforces mature response and reduces uncertainty.	T1530 remains limited to documented researcher access, not malicious access.
D – Malicious bulk access	Facilitator wants a more technical branch or participants ask for threat-hunting results.	Sentinel correlation identifies ListBlobs followed by 12 GB of GetBlob traffic from a cloud VPS IP during the exposure window. User agent suggests scripted retrieval.	Tests escalation to confirmed malicious access, updated notification, law enforcement, and threat intelligence.	T1619 and T1530 become evidenced; T1020 may be considered if automation is supported by user agent, timing, and volume.
E – Business continuity failure	Participants continue onboarding without verifying clean upload path.	New customer documents continue writing to the affected container for 45 minutes after containment discussion, increasing the possible affected population.	Tests business ownership, workflow dependencies, and compensating controls.	No additional adversary technique; operational impact increases.

13.1 Technical variation: AWS or GCP re-platforming

The default platform for this version is Azure. If the facilitator needs to adapt the exercise, replace Azure Blob Storage terms with AWS S3 or Google Cloud Storage equivalents while preserving the same control themes: public read permission, public network reachability, policy not set to deny, partial object access logs, and change-management weakness. Do not mix platforms during the exercise unless the organization actually operates multi-cloud workflows.

14. Key Decision Points

Decision	Primary decision owner	Decision criteria
Incident classification	Incident Commander with Legal/Privacy/Compliance	Security event, privacy incident, reportable breach, operational incident, or combination. Based on confirmed public access, data class, affected population, and evidentiary uncertainty.
Containment approach	Cloud Security / Cloud Platform with Incident Commander	Fastest reversible containment; preserve evidence; avoid breaking critical workflows where safe alternatives exist.
Evidence preservation	Incident Commander / Legal / Cloud Security	Configuration state, logs, object inventory, screenshots, researcher artifacts, change records, and chain of custody.
Customer impact bands	Privacy / Data Governance / Business Owner	Confirmed, probable, possible, excluded. Each band should include evidence criteria and confidence level.
Regulatory notification	Legal / Privacy / Compliance with Executive Sponsor	Sensitive data types, likelihood of harm, materiality, jurisdictional timing, and inability to rule out access.
Customer notification and support	Privacy / Legal / Communications / Customer Risk	Notification threshold, customer harm, identity protection, contact center readiness, and

Decision	Primary decision owner	Decision criteria
		customer trust.
Business continuity	Business Owner / Crisis Lead / Application Owner	Whether onboarding/mortgage workflows continue, pause, or reroute; whether clean storage and logging are validated.
Public communications	Communications with Legal, Privacy, and Executive Sponsor	Holding statement, media response, employee talking points, customer scripts, and escalation for inquiries.
Enterprise cloud posture review	CISO / Cloud Security / Risk	Scope, priority, tooling, data repositories, accountable owners, and deadlines.
Post-incident control uplift	Executive Sponsor / CISO / Cloud Platform Owner	Preventive guardrails, detective controls, logging, change approvals, data classification, and validation exercises.

15. Technical and Business Impacts

15.1 Technical impacts to explore

- Anonymous read access to customer documents in Azure Blob Storage.
- Incomplete pre-triage object-level read logs and uncertainty around external access.
- Misalignment between expected private storage architecture and actual public network/access configuration.
- Audit-only cloud policy posture where preventive deny controls were expected.
- Potential exposure of document object naming conventions and application metadata.
- Data classification gaps slowing customer impact assessment.
- Need for emergency configuration changes while preserving evidence and availability.

15.2 Business impacts to explore

- Customer trust erosion, particularly where identity and mortgage documents are involved.
- Regulatory scrutiny and requirement for incident report, notification rationale, and post-mortem.
- Fraud and identity theft risk, including targeted phishing and account takeover attempts.
- Contact center surge and complaint management.
- Delayed digital onboarding and mortgage processing if workflows are paused or rerouted.
- Media attention and reputational pressure.
- Executive and board reporting burden.
- Budget and resourcing decisions for cloud governance uplift.

16. Evaluation Criteria and Success Metrics

16.1 Success metrics by time horizon

By when	Expected outcome
First 15 minutes	Incident opened; Incident Commander assigned; report validated safely; evidence and containment owners named; privacy/legal/cloud/application owners notified.
First 30 minutes	Public access containment path selected; pre-change evidence captured; emergency change documented; decision log active; initial severity and crisis escalation evaluated.
First 60 minutes	Exposure window bounded using change records; object inventory started; affected customer bands defined; missing logging impact documented; regulator/customer notification decision path opened.
First 90 minutes	Business continuity decision made; communications posture approved; contact-center guidance drafted; fraud monitoring plan initiated; executive situation report prepared.
Next business day	Root cause documented; residual uncertainty clearly stated; notification recommendation prepared; 0–7/30/60–90 day control uplift plan owner-assigned.

16.2 Scoring rubric

Domain	1 – Ad hoc	3 – Partially effective	5 – Mature
Governance and escalation	No clear Incident Commander or decision ownership.	Incident command exists but escalation thresholds are unclear.	Roles, decision rights, crisis triggers, and executive updates are clear and timely.
Technical validation and containment	Containment delayed or performed without validation.	Containment performed but evidence or operational dependencies are incomplete.	Rapid, documented, validated containment with minimal evidence loss and business-aware compensating controls.
Evidence preservation and scoping	Facts, assumptions, and unknowns are mixed; logs are overinterpreted.	Some evidence captured, but confidence bands are weak.	Evidence log, chain of custody, customer impact bands, and logging limitations are explicit.
Privacy/regulatory decision-making	Notification discussions delayed or purely technical.	Legal/privacy involved but decision criteria are incomplete.	Reportability, harm, timing, and regulator/customer strategy are decision-ready and documented.
Business continuity and customer protection	Business operations are not engaged or risk is accepted informally.	Operational decision made but customer protection is reactive.	Workflow decision, fraud monitoring, customer support, and risk acceptance are aligned.
Communications	No approved messaging or inconsistent stakeholder communications.	Holding statement drafted but approvals/escalations unclear.	Internal, customer, regulator, media, and executive messaging are coordinated and approved.
Control improvement	Lessons learned remain generic.	Actions identified but without owners or measurable outcomes.	Owner-assigned, dated, measurable control uplift plan with validation steps.

16.3 Observer notes template

Observation area	Notes to capture
Key decisions	Decision, owner, time, rationale, dissent/alternative, and open dependencies.
Evidence handling	What was preserved, what was missed, and how logging gaps were described.
Escalation	Who was notified, when, and whether escalation matched trigger thresholds.
Communications	Whether messages were consistent, approved, and appropriate for uncertainty.
Regulatory/privacy	How data classes, customer impact, harm, and timing were assessed.
Business continuity	Whether workflow decisions considered customer impact, new uploads, and compensating controls.
Improvement actions	Owner, due date, measurable deliverable, and validation method.

17. Debrief and After-Action Review

17.1 Debrief questions

- What went well in the first hour?
- Where did decision ownership become unclear?
- Were containment and evidence preservation balanced effectively?
- How confident are we in the exposure window and affected customer bands?
- Did we avoid overstating what incomplete logs could prove?
- Were regulator and customer notification processes usable under time pressure?
- Were business continuity decisions tied to technical preconditions?
- Did communications, legal, privacy, fraud, and business owners operate from a common fact base?
- What cloud governance controls would have prevented or detected this scenario earlier?
- Which capabilities need investment in the next quarter?

17.2 After-action review structure

Section	Content
Executive summary	Incident narrative, impact, decisions, and current status.

Section	Content
Timeline	Discovery, validation, containment, escalation, scoping, communications, and resolution milestones.
Facts / assumptions / unknowns	Explicit separation of confirmed evidence, bounded assumptions, and unresolved uncertainties.
Root cause	IaC default, network exception, audit-only policy, logging gap, change approval gap, and classification gap.
Customer/regulatory assessment	Affected bands, data categories, harm analysis, notification decisions, and communications actions.
What worked	Effective processes, controls, relationships, and decisions.
Gaps	Ownership, controls, logging, tooling, data, process, or communications weaknesses.
Action plan	Owner, due date, priority, metric, and validation method.

18. Improvement Planning Template

Timeframe	Improvement action	Owner	Success metric
Immediate: 0–7 days	Confirm containment and preserve evidence package.	Incident Commander / Cloud Security	Evidence package complete and stored under legal hold or approved repository.
Immediate: 0–7 days	Complete customer impact scoping and legal/privacy assessment.	Privacy / Data Governance	Confirmed/probable/possible customer bands approved.
Immediate: 0–7 days	Enable and verify StorageRead logs for all sensitive storage accounts.	Cloud Platform / SIEM	StorageRead logs visible in Sentinel/Log Analytics with retention applied.
Immediate: 0–7 days	Prepare fraud monitoring and customer support readiness.	Fraud / Contact Center	Watchlist, scripts, and escalation path ready before notification.
Near term: 30 days	Set deny guardrail for public access to sensitive storage.	Cloud Security / Policy Owner	Azure Policy denies public blob access and public network exposure for tagged sensitive repositories.
Near term: 30 days	Review public access settings across cloud storage estate.	Cloud Security	100% of tagged sensitive storage reviewed; exceptions owner-approved and time-bound.
Near term: 30 days	Tighten approval workflow for production storage permission changes.	Change Management / Cloud Platform	Security and data owner approval required for high-risk permissions.
Near term: 30 days	Update cloud data exposure playbook.	Cyber IR / Privacy / Cloud	Playbook includes evidence checklist, escalation triggers, and notification decision flow.
Medium term: 60–90 days	Improve asset inventory and data classification coverage.	Data Governance	95%+ coverage for sensitive customer document repositories.
Medium term: 60–90 days	Implement continuous posture monitoring and alert routing.	SOC / Cloud Security	High-severity alerts for sensitive public storage routed to SOC with SLA.
Medium term: 60–90 days	Perform technical validation exercise.	Cyber IR / Cloud Platform	Repeat tabletop or purple-team simulation validates detection, containment, and scoping.
Medium term: 60–90 days	Review third-party and vendor testing exceptions.	Vendor Risk / Cloud Platform	All public network exceptions are documented, expired, or justified with compensating controls.

19. Optional Exercise Artifacts

Facilitators may prepare or hand out the following artifacts at the corresponding inject.

Artifact	Use
Researcher email	Inject 1. Establishes credible external notification and responsible disclosure pressure.

Artifact	Use
Redacted document screenshot	Inject 1. Validates real customer data without exposing live sensitive content.
Azure configuration excerpt	Inject 2. Shows publicAccess = Blob and public network access settings.
Azure Activity Log excerpt	Inject 2. Shows CI/CD service principal and timing of the control-plane change.
Diagnostic settings inventory	Inject 2. Shows missing StorageRead logs before triage.
Object inventory summary	Inject 3. Drives scoping and notification discussion.
Executive situation report template	Inject 3 or 5. Forces fact/assumption/unknown separation.
Regulator notification decision memo	Inject 3 or 5. Captures rationale and timing.
Media holding statement	Inject 4. Tests communications approval path.
Customer Q&A / contact-center script	Inject 4. Tests customer support readiness.
Control uplift backlog	Inject 5. Turns lessons learned into owner-assigned actions.

19.1 Sample researcher email

Artifact – security researcher email

Subject: Public access to customer documents in Azure Blob Storage

Hello Security Team,

I am reporting what appears to be unauthenticated public access to customer onboarding and mortgage documents hosted under your Azure Blob Storage domain. I accessed a small number of documents only to validate the finding and have redacted screenshots attached. Example URLs appear to contain customer ID and mortgage document paths. Please confirm receipt and whether this should be handled through your responsible disclosure process.

Regards,
External Researcher

19.2 Sample technical evidence excerpt

Artifact – Azure control-plane evidence

Operation: Microsoft.Storage/storageAccounts/blobServices/containers/write

Caller: spn-docops-prod

Resource: prod-doc-onboarding-eus2 / customer-documents

Observed property change: publicAccess = Blob

Network setting: publicNetworkAccess = Enabled; defaultAction = Allow

Time: Day -3, 18:47 UTC

Diagnostic setting at time of change: StorageWrite enabled; StorageRead not enabled

19.3 Executive situation report outline

- Incident summary: what happened and how it was detected.
- Current status: contained / not contained; remaining risks.
- Confirmed facts: public access, data categories, known timelines, confirmed access evidence.
- Assumptions: exposure window, customer bands, likely data categories.
- Unknowns: pre-triage object access, full affected customer count, external misuse.
- Decisions required: notification, business operations, customer protection, public communications, budget/control uplift.
- Next update time and accountable owner.

20. MITRE ATT&CK Mapping

This mapping intentionally separates baseline evidence from branch-dependent and hypothetical adversary behaviors. The baseline scenario is primarily a cloud misconfiguration and data exposure. It is not a full intrusion lifecycle unless the facilitator activates a malicious-access branch and provides additional evidence.

Evidence standard for ATT&CK mapping

Confirmed: supported by logs, artifacts, or participant-visible evidence. Inferred: plausible from the scenario but not directly proven. Branch-dependent: becomes mapped only if the facilitator activates that branch. Not evidenced: not used for scoring unless new evidence is introduced.

Status	Tactic	Technique	Scenario evidence	How to use in exercise
Confirmed baseline – non-malicious external access	Collection	T1530 – Data from Cloud Storage	Researcher provides redacted customer documents from Azure Blob URLs; post-triage controlled validation confirms anonymous read was possible.	Map carefully as external access to data from cloud storage. Do not imply malicious actor beyond the researcher unless branch evidence appears.
Not confirmed in baseline	Discovery	T1619 – Cloud Storage Object Discovery	Baseline publicAccess = Blob allows object reads if URL is known, but does not prove container listing or object enumeration.	Do not map as evidenced unless logs show ListBlobs, container listing, or enumerated object discovery.
Branch-dependent	Discovery / Collection	T1619 followed by T1530	Branch D provides ListBlobs followed by high-volume GetBlob from a cloud VPS IP.	Use when testing escalation to confirmed malicious access and updated notification decisions.
Branch-dependent	Exfiltration	T1020 – Automated Exfiltration	Branch D includes scripted retrieval pattern, volume burst, repeated requests, or user-agent evidence supporting automation.	Use only if the facilitator provides evidence of automated bulk retrieval.
Not evidenced in baseline	Exfiltration	T1567.002 – Exfiltration to Cloud Storage	No evidence that a malicious actor transferred bank documents to an attacker-controlled cloud storage service.	Exclude from baseline scoring. Use only if a later branch reveals upload/republication to another cloud service.
Explicitly absent	Impact	Ransomware / destructive techniques	No ransomware note, encryption, destructive action, privilege escalation, or malware is observed.	Do not introduce ransomware unless designing a different scenario.

20.1 Defensive data sources and detection opportunities

Detection need	Relevant data source	Example telemetry
Control-plane change detection	Azure Activity Logs / IaC pipeline logs	Container ACL change, storage account network rule update, caller spn-docops-prod, pull request and deployment ID.
Object access detection	Azure Storage resource logs to Log Analytics / Sentinel	GetBlob, GetBlobProperties, ListBlobs, caller IP, authentication type, user agent, request URI.
Public exposure posture	Azure Policy / Defender for Cloud / CSPM	Public blob access enabled, public network access enabled, policy noncompliance, missing sensitive-data tag.
Identity context	Entra ID audit and sign-in logs	Service principal activity, deployment identity, privileged role assignment, unusual sign-in.
Network path	Application Gateway/WAF/CDN logs	Portal-mediated access and exposed URL references; not sufficient for direct blob endpoint access.
Customer impact	Object inventory, data classification, DLP, customer master, records management	Object-to-customer mapping, document type, upload date, classification confidence, retention status.

20.2 MITRE reference notes

- T1530 – Data from Cloud Storage: relevant when data stored in services such as Azure Storage, Amazon S3, Google Cloud Storage, OneDrive, or similar is accessed.
- T1619 – Cloud Storage Object Discovery: relevant when storage containers, buckets, or objects are enumerated.
- T1020 – Automated Exfiltration: relevant only where evidence supports automated collection or transfer.
- T1567.002 – Exfiltration to Cloud Storage: relevant only if data is moved to an attacker-controlled cloud storage service.
- Reference source: MITRE ATT&CK Enterprise, accessed July 2026: <https://attack.mitre.org/>

21. Glossary

Term	Definition
ACL	Access control list; configuration determining who can access a resource.
ATT&CK	MITRE framework describing adversary tactics, techniques, and procedures.
Azure Blob Storage	Microsoft cloud object storage service used to store unstructured data such as documents.
CI/CD	Continuous integration / continuous deployment pipeline used to deploy code or infrastructure changes.
CSPM	Cloud security posture management; tooling that monitors cloud configuration risks.
DLP	Data loss prevention; controls that detect or prevent unauthorized movement of sensitive data.
Entra ID	Microsoft identity platform formerly known as Azure Active Directory.
GetBlob	Azure Storage data-plane operation used to retrieve a blob object.
IaC	Infrastructure as Code; machine-readable cloud infrastructure definitions such as Terraform, Bicep, or ARM templates.
Incident Commander	Person accountable for coordinating incident response activities, cadence, decisions, and documentation.
KYC	Know Your Customer; banking identity and due-diligence process.
ListBlobs	Azure Storage operation used to list blobs in a container; evidence of enumeration if performed externally without authorization.
P1 / SEV2	Example severity labels. Organizations should adapt labels to their own incident taxonomy.
PII	Personally identifiable information.
SAS	Shared Access Signature; a time-bound token granting scoped access to Azure Storage.
SIEM	Security information and event management platform, such as Microsoft Sentinel.
SOC	Security Operations Center.
WAF	Web Application Firewall.

22. Source-to-Scenario Traceability

Source element	Preserved in revised exercise	Enhanced in revised exercise
Banking organization running cloud-hosted onboarding and mortgage workflows	Core scenario remains digital onboarding, KYC, and mortgage workflows.	Added specific Azure architecture and banking data categories.
Cloud document storage containing onboarding documents, ID images, and mortgage artifacts	Customer document exposure remains the central event.	Added object inventory, data classes, customer impact bands, and classification gaps.
Cloud storage misconfiguration creating unauthenticated public access	Baseline incident remains a public cloud storage exposure.	Added concrete control-state details: publicAccess = Blob, public network access, policy audit-only, and change pipeline evidence.
Initial researcher disclosure inject	Researcher disclosure remains Inject 1.	Added responsible disclosure handling, evidence preservation, and external validation details.
Scoping, access evidence, and notification decisions	Scoping and notification remain central decisions.	Added logging source inventory, missing StorageRead logs, customer bands, and regulatory decision memo.
Courses of action: lockdown, logging review, cloud guardrails	Containment and improvement planning remain central expected actions.	Added 0–7/30/60–90 day owner-assigned actions and success metrics.

Source element	Preserved in revised exercise	Enhanced in revised exercise
Evaluation feedback	Feedback is integrated into the structure and content.	Added feedback integration table, ATT&CK evidence standards, branching injects, formal scoring, and escalation mechanics.

Distribution title

Cloud Misconfiguration Exposing KYC and Mortgage Documents — Cyber Tabletop Exercise, Revised Facilitation Package